

ANVEXA SECURITY SOLUTIONS PRIVATE LIMITED

Information Security, Data Protection and Incident Management Policy

Document ID	ASS-ISP-001
Version	3.2
Classification	Internal
Policy owner	Chief Information Security Officer (CISO)
Approved by	Board of Directors, 28 March 2026
Effective date	1 April 2026
Next scheduled review	March 2027

Anvexa Security Solutions is a fictional company. This document is a synthetic sample written to exercise a policy-scanning tool; it is not a real organisation's policy and is not legal advice.

1. Purpose and Scope

Anvexa Security Solutions Private Limited ("Anvexa", "the Company") provides managed detection and response, vulnerability assessment and security consulting services to enterprise customers in India and abroad. This information security policy sets out how the Company protects the confidentiality, integrity and availability of its own information and of the personal data and customer data entrusted to it.

The policy applies to all directors, employees, contractors and interns, and to every ICT system, application, cloud service and device that stores or processes Company or customer information, wherever it is located.

It is written to support the Company's obligations under the Digital Personal Data Protection Act, 2023 (DPDPA), the CERT-In Directions of 28 April 2022 issued under section 70B(6) of the Information Technology Act, 2000, the GDPR for customers in the European Union, and our ISO 27001:2022 certification programme.

2. Governance and Responsibilities

This information security policy is approved by the Board of Directors, communicated to all staff on joining and whenever it changes, and reviewed at least once a year. An annual review is carried out by the CISO and presented to the Board as part of the management review. The policy is also reviewed after any major incident or significant change to our systems or services.

The Chief Information Security Officer (CISO) owns this policy, reports to the Managing Director, and is responsible for the information security programme. The Data Protection Officer (DPO) oversees compliance with privacy law. Department heads are accountable for applying this policy in their teams.

We apply segregation of duties so that no single person can request, approve and implement a sensitive change. Code is not deployed to production by the developer who wrote it, access requests are approved by someone other than the requester, and the person who reviews security logs does not administer the systems being logged. Conflicting duties are identified and separated whenever roles are defined.

Employees who breach this policy are subject to disciplinary action under the Company's sanction policy, which may include termination of employment and referral to law enforcement where the law requires.

3. Risk Management

The Company maintains a cybersecurity risk management strategy approved by senior leadership. It defines our risk appetite and risk tolerance, and sets the priorities for security investment.

A formal risk assessment is performed at least annually and whenever a significant system or service changes. Each assessment identifies threats and vulnerabilities, rates the likelihood and impact of each risk, and records the result in the risk register together with an owner and a treatment plan. Risks above our risk tolerance are escalated to the CISO and the Managing Director.

The Company has identified its stakeholders, including customers, regulators, employees and partners, and documents the legal, regulatory and contractual cybersecurity obligations that apply to it.

4. Asset Management

The IT team maintains an asset inventory (also called the asset register) covering hardware, software, cloud services and data assets. Each asset has a named owner and is classified as Public, Internal, Confidential or Restricted. The asset inventory is reconciled against our discovery tools every quarter, and assets that are retired are securely wiped or destroyed with a certificate on file.

5. Access Control and Authentication

Access control follows the principle of least privilege. Access is granted through role based access control, and authorization for each role is approved by the system owner before it is given. Access rights are reviewed every quarter, and removed on the same day an employee leaves or changes role.

Every user has a unique ID; shared accounts are not permitted. Multi-factor authentication (MFA) is mandatory for all administrator access, remote access, VPN and cloud consoles. Strong authentication is enforced for all other systems.

Password complexity rules require at least 12 characters, with no commonly used passwords. Passwords are stored only as salted hashes. Sessions time out after 15 minutes of inactivity and privileged sessions are recorded.

6. Personal Data Protection

6.1 Consent and notice. We obtain explicit, informed consent from data principals before processing their personal data, except where the law allows processing for another lawful purpose. Our privacy notice is given before collection and states the purpose of processing, the retention period, the data principal rights and how to contact us. A record of consent, with date and time, is kept in our audit records.

6.2 Withdrawal. Consent can be withdrawn at any time through account settings or by writing to the DPO. A withdrawal mechanism is provided that is as easy to use as giving consent, and the withdrawal takes effect within 7 days.

6.3 Purpose limitation and minimisation. Personal data is collected only for a specified and legitimate purpose, and we do not make secondary use of it without fresh consent. We collect only data that is necessary, adequate and relevant, and review data collection forms every year as part of our data minimisation practice.

6.4 Retention. Personal data is kept only for the retention period stated in the privacy notice. Customer account data is retained for 3 years after the last interaction. After the purpose is fulfilled, data is securely deleted, in line with the storage limitation principle.

6.5 Rights of data principals. Individuals have the right to access their data and obtain a copy, the right to correction and rectification, and the right to erasure. Requests are answered within 15 days. Requests are made to privacy@anvexa.example.

6.6 Grievance redressal. Our Grievance Officer handles complaints about the processing of personal data. The complaint process is published on our website, and every complaint is acknowledged within 48 hours

and resolved within a timeline of 15 days.

6.7 Data Protection Officer. The Company has appointed a Data Protection Officer (DPO). The DPO's contact details are published in the privacy notice. The DPO is responsible for monitoring compliance, advising on privacy risk and acting as the contact point for the Data Protection Board of India and for the supervisory authority where GDPR applies.

6.8 Lawful basis. Where GDPR applies, personal data is processed in a lawful, fair and transparent manner. For each processing activity we record the lawful basis, which will be consent, contract, legal obligation or legitimate interest.

6.9 Children's data. The Company's services are not directed at children and we do not knowingly collect children's data. Where a customer asks us to process the personal data of a child, we require verifiable parental consent and age verification first.

6.10 Cross-border transfer. Production data of Indian customers is stored in data centres in India in line with data localization commitments. Transfers outside India happen only to countries permitted by the Government of India, with contractual safeguards, and with the data principal's consent where required.

7. Encryption and Cryptography

Personal and customer data is protected by encryption. Data at rest is encrypted using AES-256, including laptops, databases, object storage and backups. Data in transit is protected with TLS 1.2 or higher, and secure transmission is enforced for all internal and external connections. Encryption keys are held in a managed key store, rotated every year, and access to keys is limited to named custodians.

Hashing and digital signatures are used to maintain data integrity for backups and software releases. These measures protect the confidentiality and integrity of information against unauthorised disclosure or change.

8. Network and Platform Security

The Company operates firewalls at all network boundaries with documented inbound/outbound rules, which are reviewed every six months. Network segmentation separates the production environment, the corporate network and the guest network, so that a compromise in one zone does not give access to another.

Systems are built from hardened baselines under our secure configuration standard, with configuration management tools detecting drift. Patch management applies critical security patches within 7 days of release and other patches within 30 days. A vulnerability scan of internal and external systems is run every month, and an independent penetration test is carried out every year. Network traffic is monitored by IDS/IPS sensors.

9. Secure Development

Our software development lifecycle requires secure coding standards, peer code review and automated security testing before release. Each build is checked by a vulnerability scan of its dependencies, and findings of high severity must be fixed before deployment. Production and development environments are separate, and production data is never used for testing.

10. Logging and Monitoring

Logging is enabled on all ICT systems, including servers, network devices, applications and cloud services, creating an audit trail of administrative activity and access to customer data. Logs are reviewed daily by the security operations team, with log review of privileged activity every week.

Our security monitoring provides continuous monitoring of networks, endpoints and applications, with anomaly detection and correlation of security events in a central platform. Alerts are triaged around the

clock.

Log retention: logs of all ICT systems are retained for a rolling period of 180 days and are stored within Indian jurisdiction, in line with the CERT-In Directions. Logs are protected from alteration and deletion.

Time synchronisation: the clocks of all ICT systems are synchronised using the NTP servers of the National Informatics Centre (NIC) and the National Physical Laboratory (NPL), or servers traceable to them.

11. Incident Management and Reporting

11.1 Incident response. The Company maintains a documented incident response plan covering detection, containment, eradication, recovery and a post-incident review. The incident response plan is tested through a tabletop exercise at least once a year. Staff must report any suspected security incident to the Security Operations Centre immediately.

11.2 Reporting to CERT-In. Cyber incidents are reported to CERT-In within 6 hours of being noticed or brought to our notice, by email to incident@cert-in.org.in. Our incident reporting procedure names the Security Operations lead as the person who files the report with the details CERT-In requires.

11.3 Reportable incident types. Our incident categories follow CERT-In Annexure I. They include unauthorised access to systems or data, malicious code attacks such as malware, ransomware and botnets, phishing and spoofing attacks, denial of service and DDoS attacks, data breach and data leak, and attacks on applications and cloud services.

11.4 Point of contact. The CISO is our designated point of contact for CERT-In. The name, address, email and telephone number of the point of contact are shared with CERT-In and are kept up to date whenever the role changes.

11.5 Personal data breach notification. A personal data breach is assessed within 24 hours. We notify the Data Protection Board of India and each affected data principal as the law requires. Where GDPR applies, the supervisory authority is notified within 72 hours of becoming aware of the breach.

11.6 Cooperation. We comply with the CERT-In Directions. Logs and information requested by CERT-In are provided on request, and we cooperate with CERT-In and law enforcement during incident response.

11.7 Communication. Incident communication to customers, regulators and the public is approved by the Managing Director and coordinated by the CISO, using the stakeholder communication templates in the incident response plan.

12. Backup, Continuity and Recovery

Systems and data are covered by a business continuity plan. Encrypted backup of production data is taken daily and stored in a second Indian region. Recovery from backup is tested every quarter, and the ability to restore is verified by restoring a sample into an isolated environment.

Recovery objectives are defined for each critical service: a recovery time objective (RTO) of 4 hours and a recovery point objective (RPO) of 24 hours. The recovery plan is reviewed after each test and after each major incident, and lessons learned are recorded and acted on to improve resilience and availability.

13. Third-Party and Supplier Security

Suppliers and third-party service providers that handle Company or customer data are assessed before onboarding as part of our vendor risk process. Contracts include cybersecurity requirements, a duty to report incidents, and the right to audit. High-risk suppliers are reassessed every year, and the supply chain risk register is reviewed by the CISO each quarter.

14. Security Awareness and Training

All staff complete security awareness training when they join and every year after. Training covers phishing, password hygiene, handling of personal data and how to report an incident. We run phishing simulations every quarter and send security reminders when a new threat appears. Staff in engineering and operations receive additional role-specific education, and malware protection is explained in the onboarding programme.

15. Policy Exceptions and Review

Exceptions to this policy must be requested in writing, risk-assessed by the CISO and approved by the policy owner for a fixed period. All exceptions are recorded and reviewed at each management review.

This policy is reviewed annually. Changes are approved by the Board of Directors and communicated to all staff.